ITAR DLP Pack — Microsoft Purview

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — ITAR DLP Pack in Microsoft Purview 5
- The problem . . . 5
- The solution . . . 5
- How it works . . . 5
- Why it matters . . . 5
- Important boundaries . . . 6

1. Solution Overview — ITAR DLP Pack (Microsoft Purview) 6
- What this solution is . . . 6
- Why this matters . . . 6
- How it works . . . 7
- What you can control . . . 8
- What stays with your export-control / legal authority (be explicit) . . . 8
- Licensing reality (verify for your tenant) . . . 8
- The standard deployment model . . . 9

2. Requirements Guide — ITAR DLP Pack (Microsoft Purview) 9
- 2.1 DLP-capable compliance licensing (and what it unlocks) . . . 9
- 2.2 Least-privilege DLP administration roles . . . 9
- 2.3 Security & Compliance PowerShell + Microsoft Graph toolchain . . . 10
- 2.4 A defined technical-data detection approach (classification method) . . . 10
- 2.5 In-scope workloads and endpoint onboarding status . . . 10
- 2.6 Export-compliance / legal / records stakeholders (the determination owners) . . . 11
- 2.7 Graph read scope for DLP evidence (read-only) . . . 11
- 2.8 A pilot scope, simulation mode, and change control . . . 11
- Checklist . . . 11

Global Requirements — Microsoft Purview Solutions 12
- 1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12
- 2. Purview roles (least-privilege) and portal access . . . 12
- 3. Security & Compliance PowerShell + Graph toolchain . . . 13
- 4. Data sources & scope in scope . . . 13
- 5. Compliance, records, privacy & legal stakeholders . . . 13
- 6. A pilot scope and change control . . . 14

3. Implementation Guide — ITAR DLP Pack (Microsoft Purview) 14
- Named artifacts . . . 14

Part A — Assess & design 15
- Step 1 — Assess the estate (read-only) . . . 15

Step 2 — Design the technical-data detection (Design) . . . 15
Part B — Configure in simulation & pilot 16
Step 3 — Create the DLP policy in simulation/test (Configure) . . . 16
Step 4 — Pilot & tune (Pilot) . . . 17
Part C — Validate & expand 17
Step 5 — Validate against pass/fail gates (Validate) . . . 17
Step 6 — Promote to enforce (Expand) . . . 17
Step 7 — Operate the evidence cadence . . . 18
5. Testing & Validation Guide — ITAR DLP Pack (Microsoft Purview) 18
Test 1 — Toolchain & permissions . . . 18
Test 2 — Coverage & licensing (scope map) . . . 19
Test 3 — Technical-data detection accuracy (the important one) . . . 19
Test 4 — Policy created in simulation (non-blocking) . . . 19
Test 5 — Simulation evidence is produced . . . 20
Test 6 — Validation gates green before enforce . . . 20
Test 7 — Enforcement behaves as designed . . . 20
Test 8 — Rollback works . . . 20
Test 9 — Drift detection . . . 21
Acceptance checklist . . . 21
6. Troubleshooting — ITAR DLP Pack (Microsoft Purview) 21
Detection / classification . . . 21
Policy / scope / mode . . . 22
Egress behaviour . . . 23
False positives (the adoption killer) . . . 23
Alerts / evidence . . . 23
Connectivity / tooling . . . 24
Best Practices — ITAR DLP Pack in Microsoft Purview 25
1. Detection is the product — invest the pilot time there . . . 25
2. Never make the export determination in the tool . . . 25
3. Always pilot in simulation/test first . . . 25
4. Make the egress action proportionate . . . 26
5. Cover every egress channel — email is not enough . . . 26
6. Know the boundary between egress control and deemed-export access . . . 26
7. Confirm the right sovereign cloud before you build . . . 26
8. Change everything under control, `-WhatIf` first . . . 26
9. Baseline and watch for drift . . . 27

10. Verify against your tenant — the surfaces evolve 27
11. Keep the evidence trail intact 27
8. Deliverables Summary — ITAR DLP Pack (Microsoft Purview) 27
Documentation 27
PowerShell tools (5) — Security & Compliance PowerShell / Graph 28
Definition of done 30
Appendix A — PowerShell Scripts 31

Executive Summary — ITAR DLP Pack in Microsoft Purview

The problem

ITAR **technical data** — the drawings, models, specifications, source code, and documentation tied to defense articles on the U.S. Munitions List — must not reach a **foreign person** or leave the United States without authorization. In a Microsoft 365 environment that data moves constantly: it is emailed, shared, posted in Teams, and copied to USB drives and personal cloud storage. A single controlled file forwarded to a personal mailbox, shared to "anyone with the link," or dropped on a thumb drive can be an unauthorized export. Left unaddressed, that is both a **compliance gap** and a **serious data-risk exposure** — and "we assume people are careful" is not a control an auditor accepts.

The solution

This solution implements an **ITAR-aligned Data Loss Prevention pack in Microsoft Purview**: technical-data **detection** plus **egress control**, with the **evidence** to prove it. It delivers:

- A **technical-data classification** tuned to export-control signals — the Arms Export Control Act / ITAR warning legend, distribution statements, USML references, controlled drawing/part conventions, and an `Export Controlled // ITAR` **sensitivity label** — not generic PII detection.
- A **DLP policy** that detects that content and **controls its egress** across Exchange, SharePoint, OneDrive, Teams, and (where licensed) endpoints — blocking or restricting external send, external sharing, and removable-media/cloud upload.
- The **evidence artifact** — matches, actions, and DLP alerts — that demonstrates the control is live and working, for internal review and external audit.

How it works

We follow a repeatable model — **Assess** → **Design** → **Configure** → **Pilot (simulate)** → **Validate** → **Expand (enforce)**. The policy is always built and run in **simulation/test first**, so you see exactly what it *would* have caught, tune the detection until real technical data is caught and routine work is not, and only then promote it to enforce — in a change window, reversibly. Every configuration change is previewed (`-WhatIf`) before it is applied.

The solution ships as **self-guided documentation plus five PowerShell tools** (Security & Compliance PowerShell / Microsoft Graph) that discover the estate, scaffold the policy in simulation, validate it against pass/fail gates, produce the evidence report, and check coverage/licensing — all **read-only or `-WhatIf`/simulation by default**, with **no credentials in code**.

Why it matters

- **Detects and controls the exact ITAR risk** — the movement of technical data out of the tenant, across every channel it actually travels.

• **Defensible by design** — piloted in simulation, validated against explicit gates, and evidenced with an auditable artifact rather than a claim.

• **Tuned, not blunt** — detection keyed to export markings and a controlled-data label, so it protects the right content without blocking legitimate engineering work.

• **A fraction of consulting cost** — the same disciplined method a specialist would use, delivered as a repeatable, tested runbook.

Important boundaries

This solution delivers the **technical control and the evidence — not the ITAR determinations**. Whether an item **is** controlled technical data, whether a person is a **U.S. person** or a **foreign person**, USML categorization, ITAR-vs-EAR jurisdiction, licensing/authorization, **deemed-export** access decisions, and the required cloud environment (Commercial vs **GCC High / DoD**) are **legal/export determinations** made by your **Empowered Official, export-compliance officer, and legal** functions. DLP controls **egress out of the tenant**; preventing **internal access by foreign persons** (the deemed-export problem) is a separate access-control design and is flagged, not solved, here. Purview DLP is **licensing-dependent** (Endpoint DLP / EDM generally require Microsoft 365 **E5** or the **E5 Compliance** add-on; some capabilities may be in preview) and the portal is **evolving** — capability availability and paths should be **verified against your licensing and tenant**.

1. Solution Overview — ITAR DLP Pack (Microsoft Purview)

What this solution is

ITAR **technical data** — the drawings, models, specifications, schematics, source code, test data, and documentation associated with defense articles on the **U.S. Munitions List (USML)** — must not be disclosed to a **foreign person** or transmitted out of the United States without authorization. In a Microsoft 365 tenant that means export-controlled technical data cannot be allowed to leak out through email, SharePoint/OneDrive sharing, Teams, or endpoint channels (USB, print, cloud upload), and every attempt must leave an **audit trail** you can show an export-compliance authority or auditor. This solution is the **Data Loss Prevention (DLP) pack** for ITAR technical data in **Microsoft Purview**: a technical-data detection classification set, a DLP policy that controls egress across the M365 workloads, and the **evidence** (alerts, activity, reports) that demonstrates the control is live and working — configured, **piloted in simulation/test first**, validated against pass/fail gates, and then enforced.

It is built entirely from the **Microsoft Purview portal**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** — no third-party tooling. Five PowerShell scripts do the discovery, the simulation-first configuration, the validation, the evidence reporting, and a scope/health check.

Why this matters

• **Uncontrolled egress of technical data is the exact ITAR risk.** A single controlled drawing forwarded

to a personal mailbox, shared to "Anyone with the link," posted where a foreign-person colleague can read it, or copied to a thumb drive can be an unauthorized export or **deemed export**. DLP is the technical control that detects that movement and stops or restricts it.

- **Detection must be tuned to technical data, not generic PII.** Export-controlled technical data is not

identified by an SSN or a credit-card number — it is identified by **export-control markings** (ITAR/USML references, distribution statements, the Arms Export Control Act warning legend), controlled drawing/part-number conventions, and program context. That is a custom classification, not an off-the-shelf template. Getting detection right is most of the work.

- **Enforcing blind breaks engineering work.** Flip a block policy on across a defense-program tenant with

no tuning and you will block legitimate collaboration and generate a flood of false positives. Every policy here is **piloted in simulation/test** so you see what *would* have matched, tune it, and only then enforce.

- **"We have DLP" is not evidence.** An export-compliance reviewer asks *show me*: which policy, what it

detects, what it restricts, and the record of matches and admin actions. This pack produces that evidence as an artifact, not a claim.

- **Coverage gaps are silent.** Technical data moves through email, collaboration, and endpoints. A policy

scoped to Exchange only leaves SharePoint, Teams, and USB wide open. The scope/health check makes coverage explicit and licensing-aware.

How it works

1. **Assess.** `DLPITAR-Discovery.ps1` (read-only) inventories existing DLP policies and rules, the

sensitive-information-types available in the tenant, and whether any technical-data classification already exists — so you build on what's there and avoid duplicate/overlapping policies.

1. **Design the technical-data classification.** Define how ITAR technical data is detected in *your*

environment: a **custom sensitive information type** and/or **keyword dictionary** for export-control markings and controlled drawing/part conventions, optionally combined with **sensitivity labels** (e.g. an "Export Controlled // ITAR" label) so labeled content is protected directly. *(What data is ITAR-controlled technical data — and who is a foreign person — is a determination for your export-control / legal authority, not this solution; the pack provides the detection and egress method, not the export classification.)*

1. **Configure in simulation/test.** `DLPITAR-Set-Policy.ps1` creates the ITAR DLP policy and its

detection rule across the in-scope workloads in **test mode** (`TestWithNotifications` / `TestWithoutNotifications`) — `-WhatIf` by default, writing only with `-Commit`. Nothing blocks yet.

1. **Pilot & tune.** Let the policy run in simulation over the pilot period; review what it matched with

`DLPITAR-Report.ps1`. Tune the classification and rule confidence/instance thresholds until the match set is right — real technical data caught, routine work not flagged.

1. **Validate.** `DLPITAR-Validation.ps1` (read-only) checks the deployed policy against explicit

pass/fail gates: correct workload scope, the detection rule present with the intended egress action, and the policy in the expected mode.

1. **Enforce & expand.** Once simulation is clean, promote the policy to **enforce** (block/restrict

external send and sharing) in a change window with `DLPITAR-Set-Policy.ps1 -PromoteToEnforce -Commit`, then extend scope (e.g. Endpoint DLP for USB/print/cloud upload) as licensing allows. Rollback is a single command back to test/disabled.

1. **Evidence, continuously.** `DLPITAR-Report.ps1` produces the ongoing evidence artifact — matches,

actions, and DLP alerts (via Graph) — for export-compliance audit and internal review.

What you can control

• The technical-data detection definition — which markings, keywords, drawing/part patterns, and

supporting labels/SITs, and the confidence / instance-count thresholds that decide a match.

• The in-scope workloads (Exchange, SharePoint, OneDrive, Teams, and — licensing permitting — endpoints)

and the policy's user/site scope.

• The egress action (block external send/share, block-with-override, restrict to internal/authorized

recipients only, notify) and the policy tip / notification wording.

• The pilot scope and duration, and the change-control path for promoting to enforce.

• The evidence cadence and what the report captures for your reviewer.

What stays with your export-control / legal authority (be explicit)

This solution delivers the **technical DLP control and the evidence** — not the **ITAR determinations**. Whether a given item *is* ITAR-controlled technical data, whether a person is a **U.S. person** or a **foreign person**, USML categorization, jurisdiction/classification (ITAR vs EAR), licensing and authorization decisions, **deemed-export** access authorization, and Technology Control Plan (TCP) obligations are the responsibility of your **Empowered Official, export-compliance officer, and legal** functions. DLP is one control in a broader ITAR compliance program; this pack implements and evidences that one control well and defers the export determinations to the accountable owners. In particular, DLP controls **egress out of the tenant**; controlling **internal access by foreign persons** (the classic deemed-export problem) is primarily an access-control / sensitivity-label / Conditional Access design driven by a legal foreign-person determination — this pack flags where that boundary sits and does not make the determination.

Licensing reality (verify for your tenant)

Purview DLP is **licensing- and plan-dependent** and the portal **evolves**. DLP for Exchange Online, SharePoint, OneDrive, and Teams is broadly available; **Endpoint DLP**, **Exact Data Match (EDM)**, and **trainable classifiers** generally require **Microsoft 365 E5** or the **E5 Compliance** add-on, and some capabilities are in preview. Custom sensitive information types and keyword dictionaries are widely available but confirm for your plan. Every step below is flagged where availability depends on licensing — **confirm capability and portal paths for your own tenant** before relying on them.

The standard deployment model

> *Assess → Design (technical-data detection) → Configure (in **simulation/test**) → Pilot & tune → Validate → Expand (**enforce**). High-impact DLP changes are **always piloted in simulation/test before enforcement**, every change is `-WhatIf`-previewed and reversible, and ITAR/export/legal determinations are deferred to the accountable owners.*

2. Requirements Guide — ITAR DLP Pack (Microsoft Purview)

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-purview.md` (the six shared requirements: compliance licensing, least-privilege Purview roles, the S&C PowerShell + Graph toolchain, in-scope data sources, compliance/records/privacy/legal stakeholders, and a pilot scope with change control) — those are referenced here, not repeated.

2.1 DLP-capable compliance licensing (and what it unlocks)

Description: A confirmed inventory of the tenant's **compliance licensing** for DLP. DLP for Exchange Online, SharePoint, OneDrive, and Teams is broadly available; **Endpoint DLP**, **Exact Data Match (EDM)**, and **trainable classifiers** generally require **Microsoft 365 E5** or the **E5 Compliance** add-on (Global Requirement 1). **Why:** Technical data moves through endpoints (USB, print, cloud upload) as well as mail and collaboration; how far your ITAR DLP coverage can reach depends on the plan. Scope the pack to what you can actually enforce. **Verify:** Microsoft 365 admin center → `Billing → Licenses` for subscriptions/add-ons; `DLPITAR-Scope-Health.ps1` reports which DLP surfaces (workloads / endpoints) are licensed and onboarded. Confirm DLP is visible in the Purview portal → `Data loss prevention` (verify path in your tenant). **Implement:** Assign/purchase the required licensing before relying on a surface that needs it. Where a surface is unlicensed (e.g. Endpoint DLP without E5), record it as a coverage gap rather than assuming it is protected.

> ***Sovereignty note (verify).** Defense programs frequently require a U.S. sovereign cloud (**GCC High** or **DoD**). Purview capability availability, portal paths, and Graph/PowerShell endpoints differ across **Commercial / GCC / GCC High / DoD** — the scripts accept a `-ConnectionUri` / Graph environment for this reason. **Which cloud your ITAR data must reside in is an export/legal determination** (see Requirement 2.6), not a technical default; confirm your tenant's environment before relying on any path below.*

2.2 Least-privilege DLP administration roles

Description: An account holding the least-privilege Purview role to author DLP — **Compliance Administrator** or **Compliance Data Administrator**, or the **DLP Compliance Management** role for policy authoring; **Information Protection** roles for reviewing matched content — with Global Administrator reserved only for one-time consent actions (Global Requirement 2). **Why:** DLP policies and matched-content review can expose controlled technical data; the fine-grained role model limits who can see and change them. Over-granting Global Admin undermines the control you are building. For ITAR, the administrator and matched-content reviewer should themselves be **U.S. persons** where your program's TCP requires it — an access determination for your export authority, not this solution. **Verify:** Purview portal → `Settings → Roles & scopes → Role groups` (verify path) — confirm your account is in

Compliance Administrator (or a role group containing **DLP Compliance Management**). `Connect-IPPSSession` succeeds and `Get-DlpCompliancePolicy` returns. **Implement:** Add the account to the least-privilege compliance role group under change control; keep who **administers** DLP separate from who **reviews** matched technical-data content.

2.3 Security & Compliance PowerShell + Microsoft Graph toolchain

Description: A workstation with the **ExchangeOnlineManagement** module (provides `Connect-IPPSSession` for the DLP cmdlets) and the **Microsoft Graph PowerShell SDK** (for reading DLP alerts), with a modern-auth / MFA admin account (Global Requirement 3). **Why:** Every script in this pack runs through S&C PowerShell (`*-DlpCompliancePolicy` / `*-DlpComplianceRule`) and/or Graph (`/security/alerts_v2`). **Verify:** `Get-Module -ListAvailable ExchangeOnlineManagement, Microsoft.Graph.Authentication`; `Connect-IPPSSession` and `Connect-MgGraph` both succeed. `DLPITAR-Discovery.ps1` reports connectivity. **Implement:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` and `Install-Module Microsoft.Graph -Scope CurrentUser`; confirm modern-auth sign-in. For a sovereign cloud, pass the matching `-ConnectionUri` and Graph environment (GCC High / DoD).

2.4 A defined technical-data detection approach (classification method)

Description: An agreed way to **detect ITAR technical data** in your content — a **custom sensitive information type** (regex + keyword evidence) and/or a **keyword dictionary** for export-control markings and controlled drawing/part conventions, ideally combined with a **sensitivity label** (e.g. `Export Controlled // ITAR`) so labeled content is protected directly, and — where licensed — **EDM** against a known controlled-item identifier set for high precision (Global Requirement 4). Typical building blocks: the **Arms Export Control Act / ITAR warning legend**, **distribution statement** markers (e.g. Distribution Statement B–F), **USML category** references, `22 CFR 120–130` citations, and your program's controlled drawing-/part-number formats. **Why:** Detection accuracy is most of a DLP program. Generic PII SITs do not identify technical data; marking- and context-driven classification with the right confidence/instance thresholds is what makes the policy usable. **Verify:** `DLPITAR-Discovery.ps1` lists existing SITs and any technical-data custom type; confirm with your export-compliance authority which markings, terms, and identifiers define in-scope technical data. **Implement:** Author the custom SIT / keyword dictionary in the Purview portal → `Data classification → Classifiers → Sensitive info types` (verify path), and/or the label in `Information protection → Labels`, before authoring the DLP rule. *(What data **is** ITAR technical data — and who is a foreign person — is a determination for your Empowered Official / export-compliance authority. This requirement is the detection method, not the export classification.)*

2.5 In-scope workloads and endpoint onboarding status

Description: The **workloads in scope** for technical-data control — Exchange Online, SharePoint Online, OneDrive, Teams, and (licensing permitting) **onboarded endpoints/devices** — and the user/site scope the policy will target (Global Requirement 4). **Why:** DLP keys off the in-scope workloads; endpoints must be explicitly onboarded before Endpoint DLP can restrict USB/print/cloud-upload, and a mail-only policy leaves collaboration and removable-media channels open — a common ITAR egress path. **Verify:** `DLPITAR-Scope-Health.ps1` reports M365 workload availability and endpoint device-onboarding status from the Purview device-onboarding surface. Confirm the in-scope list with stakeholders.

Implement: Define the scope; plan endpoint onboarding (Purview portal → `Settings → Device onboarding`, verify path) if Endpoint DLP is in scope and licensed.

2.6 Export-compliance / legal / records stakeholders (the determination owners)

Description: Engagement with the **Empowered Official, export-compliance officer, and the legal, records, security, and privacy** stakeholders whose policy the configuration must satisfy — including the egress action (block external vs allow-with-justification), the **foreign-person / U.S.-person** determination that drives any access restriction, the notification wording, the required cloud environment (Commercial vs GCC High / DoD), and the technical-data retention/records position (Global Requirement 5). **Why:** DLP enforcement affects engineering collaboration and must align to the ITAR program and its **Technology Control Plan**, not technical defaults. Export classification, foreign-person status, licensing/authorization, and records determinations are theirs to make — this solution provides the control and the evidence, never the determination. **Verify:** Named approvers recorded; the egress action, override policy, foreign-person access position, and evidence requirements agreed in writing. **Implement:** Identify the owners and capture the requirements before enforcing anything.

2.7 Graph read scope for DLP evidence (read-only)

Description: The delegated Graph scope needed for the evidence report to read DLP alerts: `SecurityEvents.Read.All` (and `SecurityAlert.Read.All` where required for `alerts_v2`). No write scopes are required. **Why:** `DLPITAR-Report.ps1` reads triggered DLP alerts via Graph `/security/alerts_v2` to build the evidence artifact; keeping to read scopes matches the safe-by-default posture. **Verify:** `DLPITAR-Report.ps1` connects and reports if consent is missing. **Implement:** Consent at first `Connect-MgGraph`; if admin consent is required, a Global Administrator approves the read scope once in Entra (`Identity → Applications → Enterprise applications`). Use the Graph environment that matches your cloud (Global / USGov / USGovDoD).

2.8 A pilot scope, simulation mode, and change control

Description: A named **pilot scope** (`ITAR Pilot Ring – Stage1` — a limited set of users/sites) run in **simulation/test** mode first, and a **change-control** process for promoting to enforce, per Global Requirement 6. DLP supports `TestWithNotifications` / `TestWithoutNotifications` — this MUST be used before enforcement. **Why:** DLP egress-block actions are high-impact in a defense-program tenant; the policy is validated in simulation on the ring before any content is blocked, and enforcement is a reviewed, reversible promotion. **Verify:** The ring is defined, simulation mode confirmed available, and a change window / approval path exists. **Implement:** Define the ring and agree change control before promoting any policy to enforce.

Checklist

- DLP-capable licensing inventoried; endpoint/EDM/trainable-classifier availability recorded (E3 vs E5 / E5 Compliance)
- Cloud environment confirmed (Commercial / GCC High / DoD) per export/legal determination
- Least-privilege DLP role confirmed; admin vs matched-content reviewer separated

• ExchangeOnlineManagement + Microsoft Graph SDK installed; `Connect-IPPSSession` / `Connect-MgGraph` succeed

• Technical-data detection approach agreed (markings / distribution statements / drawing-part patterns / label / EDM where licensed)

• In-scope workloads agreed; endpoint onboarding status assessed

• Empowered Official + export-compliance/legal/records stakeholders named; egress action + foreign-person position + evidence requirements captured

• Graph read scope (`SecurityEvents.Read.All`) consented for the evidence report

• `ITAR Pilot Ring – Stage1` defined; simulation mode confirmed; change control agreed

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

• **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

• **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

• **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

• **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

- **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

- **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

- **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

- **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.
- **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — ITAR DLP Pack (Microsoft Purview)

This is the **build** guide: how to stand up ITAR technical-data Data Loss Prevention across the M365 workloads, pilot it in **simulation/test**, validate it, and only then enforce. Work **Part A** to assess and design, **Part B** to configure and pilot, **Part C** to validate and expand. Detection and policy come from the **Microsoft Purview portal** and **Security & Compliance PowerShell** (`Connect-IPPSSession`); DLP alerts for evidence come from **Microsoft Graph**. Every config change is run `-WhatIf` **first** and only committed with `-Commit` under change control. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention and are reused verbatim across docs, scripts, and the portal.

> ***Model:** Assess → Design (technical-data detection) → Configure (in **simulation/test**) → Pilot & tune → Validate → Expand (**enforce**). High-impact DLP changes are **always piloted in simulation/test before enforcement**; every change is reversible and recorded. Whether data *is* ITAR technical data, who is a **foreign person**, the required cloud environment, licensing/authorization, and the technical-data retention schedule are **deferred to your Empowered Official, export-compliance, and legal** functions.*

Named artifacts

Artifact	Name
Technical-data custom sensitive info type	`Technical Data SIT – Export Markings – Custom`
Technical-data keyword dictionary	`Technical Data Dictionary – ITAR Markings – Terms`
Export-controlled sensitivity label (optional)	`Export Controlled // ITAR`

Artifact	Name
DLP policy (pilot / simulation)	`ITAR Technical-Data Egress – AllWorkloads – Pilot`
DLP detection rule	`Technical-Data Egress Rule – Markings+Label – v1`
Policy baseline (drift reference)	`Policy Baseline – ITAR DLP – <date>`
Evidence report	`ITAR DLP Evidence – Egress – Report`
Workload scope map	`Workload Scope – ITAR DLP – Map`
Change record	`Change Record – ITAR DLP – ChangeControl`
Pilot ring	`ITAR Pilot Ring – Stage1`

Part A — Assess & design

Step 1 — Assess the estate (read-only)

1. Confirm least-privilege DLP administration is in place (Requirement 2.2) and connect:

`Connect-IPPSSession` (use the `-ConnectionUri` for your cloud — Commercial / GCC High / DoD).

1. Run `DLPITAR-Discovery.ps1` to inventory existing DLP policies and rules, the available

sensitive-information-types, and any technical-data / export-controlled classification already present. It writes the policy register and confirms toolchain connectivity.

1. Run `DLPITAR-Scope-Health.ps1` to produce `Workload Scope – ITAR DLP – Map`: which workloads are

available, endpoint onboarding status, and which DLP surfaces your licensing unlocks (Requirement 2.1, 2.5). **Pass:** you have a written inventory of existing DLP, available SITs, and the licensed coverage.

1. Once the current state is agreed as known-good, run `DLPITAR-Discovery.ps1 -SaveBaseline` to write

`Policy Baseline – ITAR DLP – <date>` — the reference future drift checks diff against.

Step 2 — Design the technical-data detection (Design)

1. With your Empowered Official / export-compliance stakeholders (Requirement 2.6), agree **how ITAR

technical data is detected** in your content (Requirement 2.4). Typical building blocks:

• A **custom sensitive information type** `Technical Data SIT – Export Markings – Custom` — regex for

the export-control markings and legends in scope (the **Arms Export Control Act / ITAR warning legend**, **Distribution Statement B–F** markers, **USML category** references, `22 CFR 120–130` citations) plus your

program's controlled **drawing-/part-number** formats, with **keyword evidence** to raise precision.

• A **keyword dictionary** `Technical Data Dictionary – ITAR Markings – Terms` — the export-control

terms your authority confirms (e.g. "Export Controlled", "ITAR Controlled", program/source-system labels).

• An `Export Controlled // ITAR` **sensitivity label** applied to controlled content (manually,

recommended, or — where licensed — auto-applied). A DLP rule condition **"content has label** `Export Controlled // ITAR`**"** is the most precise and durable signal, because it protects the item even after it is copied or renamed. Labeling drives the strongest DLP.

• Where **EDM** is licensed (E5), an **Exact Data Match** schema against a known controlled-item /

drawing identifier export for high-precision matching of specific records.

1. Author the custom SIT / keyword dictionary in the portal → `Data classification → Classifiers →

Sensitive info types `(verify path), and the label in` Information protection → Labels`. Set an initial **confidence level** (start Medium) and **instance count** (e.g. 1+) for the pilot; these are the primary tuning knobs. **Pass:** the technical-data classification exists and test-matches sample marked/labeled technical data but not routine documents. *(What markings/identifiers define ITAR technical data, and who is a foreign person, are your authority's determinations; this step implements the detection.)*

Part B — Configure in simulation & pilot

Step 3 — Create the DLP policy in simulation/test (Configure)

1. Confirm `DLPITAR-Set-Policy.ps1` is safe by default: with no `-Commit` it **previews** and writes

nothing. Preview the intended policy: `DLPITAR-Set-Policy.ps1 -SitName "Technical Data SIT – Export Markings – Custom" -WhatIf`.

1. Create the policy and rule in **test mode** with `-Commit`:

`DLPITAR-Set-Policy.ps1 -SitName "Technical Data SIT – Export Markings – Custom" -Mode TestWithNotifications -Commit`. This creates:

• Policy `ITAR Technical-Data Egress – AllWorkloads – Pilot` scoped to Exchange, SharePoint, OneDrive,

and Teams (and Endpoint where licensed), targeting `ITAR Pilot Ring – Stage1`.

• Rule `Technical-Data Egress Rule – Markings+Label – v1` matching the technical-data classification

(SIT and/or the `Export Controlled // ITAR` label), with the intended **egress action staged but not blocking** — the ITAR-relevant conditions are **recipient is external** / **content is shared with people outside the organization** (test mode surfaces matches and policy tips without enforcing). **Pass:** `Get-DlpCompliancePolicy` shows the policy `Mode = TestWithNotifications`; the rule exists. **Rollback:** `DLPITAR-Set-Policy.ps1 -Disable -Commit` sets the policy to `Disable` (no effect on users).

1. Confirm nothing is blocking: in test mode, users are not restricted — the policy only records what it

would have done.

Step 4 — Pilot & tune (Pilot)

1. Let the policy run in simulation over the agreed pilot period on `ITAR Pilot Ring – Stage1`.

2. Review matches with `DLPITAR-Report.ps1` — it reads DLP alerts (Graph, Requirement 2.7) and produces

`ITAR DLP Evidence – Egress – Report`: what matched, on which workload, the recipient/scope, and the (simulated) action.

1. **Tune** the technical-data classification and the rule's confidence/instance thresholds until the

match set is right — real technical-data egress caught, routine internal engineering work not flagged. Each tuning edit is previewed (`-WhatIf`) and applied (`-Commit`) and recorded in `Change Record – ITAR DLP – ChangeControl`. **Pass:** over a representative pilot window, true controlled-data egress is matched and the false-positive rate is acceptable to stakeholders. **Fail:** high false-positive rate → tighten the SIT/thresholds, prefer the label condition, and re-pilot; do **not** promote to enforce.

Part C — Validate & expand

Step 5 — Validate against pass/fail gates (Validate)

1. Run `DLPITAR-Validation.ps1` (read-only). It checks:

• The policy `ITAR Technical-Data Egress – AllWorkloads – Pilot` exists and is in the expected mode.

• It is scoped to the intended workloads (Exchange / SharePoint / OneDrive / Teams / Endpoint as

designed).

• The rule `Technical-Data Egress Rule – Markings+Label – v1` is present and references the

technical-data classification with the intended egress action (external send/share restriction). **Pass:** all gates green and the simulation results were signed off by stakeholders. **Fail:** any gate red → fix in test mode and re-validate before enforcing.

Step 6 — Promote to enforce (Expand)

1. With clean simulation results and change approval (Requirement 2.6, 2.8), preview the promotion:

`DLPITAR-Set-Policy.ps1 -PromoteToEnforce -WhatIf`.

1. In the change window, enforce:

`DLPITAR-Set-Policy.ps1 -PromoteToEnforce -Commit` — sets the policy `Mode = Enable` so the configured action (e.g. block external send / restrict external sharing / block-with-override) now applies. The change is stamped into `Change Record – ITAR DLP – ChangeControl`. **Pass:**

`Get-DlpCompliancePolicy` shows `Mode = Enable`; a controlled test triggers the action and an alert. **Rollback:** `DLPITAR-Set-Policy.ps1 -Disable -Commit` (or `-Mode TestWithNotifications -Commit`) returns it to non-enforcing immediately.

1. **Expand coverage** as licensing allows — add **Endpoint DLP** (USB/print/cloud-upload restrictions on

labeled/matched technical data) once devices are onboarded and E5 is confirmed, or tighten from allow-with-override to block. Each expansion is piloted in simulation on the ring first, validated, then enforced. Re-baseline (`DLPITAR-Discovery.ps1 -SaveBaseline`) after each approved change set. *(Controlling **internal access by foreign persons** — the deemed-export problem — is an access-control / sensitivity-label / Conditional Access design driven by a legal foreign-person determination, not a DLP egress rule. Note it as a program dependency and route it to your export authority; this pack does not make that determination.)*

Step 7 — Operate the evidence cadence

1. Run `DLPITAR-Report.ps1` on your evidence cadence to refresh `ITAR DLP Evidence – Egress – Report` —

the artifact you show a reviewer: policy in force, what it detects, matches and admin actions over time.

1. Run `DLPITAR-Discovery.ps1 -CompareBaseline` periodically to detect **drift** — any unexpected mode

change (e.g. the ITAR policy silently moved to `Disable`) is a change-control event.

Order of operations

`Assess estate + scope/licensing → design technical-data detection (prefer label) → create policy in TEST (simulation) → pilot & tune → validate gates → (approval) promote to ENFORCE → expand coverage → run the evidence cadence – every change -WhatIf-first, reversible, and recorded; ITAR/export/legal determinations (including foreign-person status and deemed-export access) deferred to the owners.`

5. Testing & Validation Guide — ITAR DLP Pack (Microsoft Purview)

Test in order. Every gate is **pass/fail** with a defined remediation. The golden rule: **prove detection and behavior in simulation/test before you enforce**, and re-validate after every change. Use a **synthetic technical-data test document** (fabricated content carrying the export-control markings/label your classification targets — **never real ITAR technical data**) for match tests.

> *Deploy model: Assess → Design → Configure (**simulate**) → Pilot & tune → Validate → Expand (**enforce**). Do not promote a policy to enforce with a failing gate.*

Test 1 — Toolchain & permissions

- **How:** `Connect-IPPSSession`; run `DLPITAR-Discovery.ps1`.

• **Pass:** the script connects, `Get-DlpCompliancePolicy` returns, and the existing-DLP/SIT inventory

prints.

• **Fail:** "not connected" → install `ExchangeOnlineManagement` and re-run `Connect-IPPSSession` with the

correct `-ConnectionUri` for your cloud (Requirement 2.3); access denied → confirm the least-privilege DLP role (Requirement 2.2).

Test 2 — Coverage & licensing (scope map)

• **How:** run `DLPITAR-Scope-Health.ps1`.

• **Pass:** `Workload Scope – ITAR DLP – Map` lists the available workloads, endpoint onboarding status,

and the DLP surfaces your licensing unlocks — with no *unexpected* gaps.

• **Fail:** a required surface (e.g. Endpoint DLP for USB/print) shows unlicensed/not-onboarded → record it

as a coverage gap and either license/onboard it or de-scope it explicitly (Requirement 2.1, 2.5). Do not assume an un-onboarded surface is protected.

Test 3 — Technical-data detection accuracy (the important one)

• **How:** with the technical-data classification authored (Step 2), test it against (a) a **synthetic

technical-data document **carrying the export markings/label and (b) a set of** routine documents** (general admin, HR, marketing) that should NOT match. Use the portal SIT test pane and/or the pilot simulation results in `DLPITAR-Report.ps1`.

• **Pass:** the synthetic technical-data document matches at the configured confidence/instance threshold;

the routine documents do **not** match.

• **Fail:** routine documents match (over-matching) → raise confidence, add required keyword evidence, or

prefer the `Export Controlled // ITAR` label condition; technical-data document does not match (under-matching) → broaden the marking regex/dictionary or lower the threshold. Re-test until both hold. **Tuning detection is expected — budget pilot time for it.**

Test 4 — Policy created in simulation (non-blocking)

• **How:** after `DLPITAR-Set-Policy.ps1 -Mode TestWithNotifications -Commit`, run

`DLPITAR-Validation.ps1`.

• **Pass:** the policy `ITAR Technical-Data Egress – AllWorkloads – Pilot` exists with `Mode =

TestWithNotifications; the rule` Technical-Data Egress Rule – Markings+Label – v1` is present; users are **not** blocked (external send/share of the synthetic technical-data doc succeeds while an alert/tip is

recorded).

• **Fail:** policy missing → re-run the create with `-Commit`; users blocked in "test" → confirm the mode is a `Test*` mode, not `Enable` (rollback with `-Disable -Commit`).

Test 5 — Simulation evidence is produced

• **How:** trigger a match with the synthetic technical-data document on each in-scope egress path (email it externally, share it to an external/consumer address, post it in Teams), then run `DLPITAR-Report.ps1`.

• **Pass:** `ITAR DLP Evidence – Egress – Report` shows the simulated matches by workload/recipient and the action that *would* have been taken.

• **Fail:** no matches recorded → detection is under-matching (see Test 3), the workload/egress path is out of scope (see Test 2), or DLP alert latency (allow time; DLP events can take minutes to surface).

Test 6 — Validation gates green before enforce

• **How:** run `DLPITAR-Validation.ps1` immediately before promoting.

• **Pass:** scope, rule presence, egress action, and mode all match the design; stakeholders have signed off the simulation results (Requirement 2.6).

• **Fail:** any gate red → do not promote; fix in test mode and re-validate.

Test 7 — Enforcement behaves as designed

• **How:** after `DLPITAR-Set-Policy.ps1 -PromoteToEnforce -Commit`, attempt the same synthetic technical-data egress from a pilot-ring account.

• **Pass:** the configured action applies (e.g. external send blocked / external share restricted / override prompt shown), an alert is generated, and `DLPITAR-Report.ps1` records the enforced action.

• **Fail:** action not applied → confirm `Mode = Enable` and the rule action; action too broad (blocks legitimate internal work) → **rollback immediately** (`-Mode TestWithNotifications -Commit`) and re-tune.

Test 8 — Rollback works

• **How:** run `DLPITAR-Set-Policy.ps1 -Disable -Commit` (or `-Mode TestWithNotifications -Commit`).

• **Pass:** the policy stops enforcing within the DLP propagation window; the synthetic technical-data action succeeds again; the change is stamped in `Change Record – ITAR DLP – ChangeControl`.

• **Fail:** still enforcing → confirm the command committed and allow propagation time; verify with `Get-DlpCompliancePolicy`.

Test 9 — Drift detection

• **How:** run `DLPITAR-Discovery.ps1 -CompareBaseline` after establishing the baseline.

• **Pass:** no unexpected drift; any mode change on the ITAR policy is explained by a recorded change.

• **Fail:** an unexplained `ModeChanged` (e.g. policy moved to `Disable`) → treat as a change-control incident and investigate.

Acceptance checklist

• Toolchain connects; least-privilege DLP role confirmed (Test 1)

• Scope map produced; coverage gaps recorded, not assumed (Test 2)

• Technical-data detection matches synthetic marked/labeled doc, not routine docs (Test 3)

• Policy created in **simulation/test**; users not blocked (Test 4)

• Simulation evidence produced across in-scope egress paths (Test 5)

• Validation gates green + stakeholder sign-off before enforce (Test 6)

• Enforcement behaves as designed (Test 7)

• Rollback verified and recorded (Test 8)

• Drift detection running against the baseline (Test 9)

6. Troubleshooting — ITAR DLP Pack (Microsoft Purview)

Symptom-first fixes for the failures you actually hit standing up ITAR technical-data DLP across email, SharePoint/OneDrive, Teams, and endpoint. Most problems reduce to one of: the technical-data classification not firing, a policy scoped or moded wrong, egress not being restricted as expected, too many false positives on routine engineering work, or matches that raise no alert/evidence. All the delivered scripts are **read-only or** `-WhatIf` **by default** — recovery is almost always a return to **simulation/test**, which changes nothing for users.

Detection / classification

The `Technical Data SIT – Export Markings – Custom` **never matches marked technical data.**

• Test the SIT's **regex, keyword dictionary, and character proximity** in the SIT wizard's **Test** step with a *fabricated* document carrying the export-control markings in scope (ITAR/USML references, distribution statements, the AECA warning legend). A too-strict regex, wrong proximity window, or a required keyword that isn't present suppresses all matches. Loosen and re-test incrementally.

• Confirm the **instance count / confidence** on the rule — if it requires several instances at High

confidence and your test document has one marking, it correctly won't fire. Lower for testing, then re-tune.

• Prefer the **label condition** where you can: a rule keyed on *content has label `Export Controlled //

ITAR`* is the most durable signal and sidesteps regex tuning entirely for labeled items.

The classification matches *too much* (routine engineering docs flagged).

• That is a precision problem, not a miss — add/require **supporting keywords** and tighten **proximity** so

a bare part-number pattern alone doesn't fire, and raise **confidence/instance count**. Where E5 permits, move a high-value identifier set to **Exact Data Match (EDM)** so only known controlled records match.

• See *False positives* below — export matches with `DLPITAR-Report.ps1` first, classify TP/FP, then tune

one driver at a time and re-simulate.

Policy / scope / mode

A DLP policy matches nothing even though the content clearly contains technical data.

• Confirm the policy is in a **mode that evaluates**: *Disable* does nothing; *TestWithNotifications /

TestWithoutNotifications* (**simulation**) evaluates and logs but does not block; *Enable* enforces. Check the mode with `DLPITAR-Discovery.ps1` or `DLPITAR-Validation.ps1`.

• **Propagation takes time** — a newly created or changed DLP policy can take **up to ~1 hour (longer for

some locations)** to take effect. Wait before concluding it's broken.

• Confirm the **workload scope** covers where you're testing and that the test identity isn't in an

exclusion or outside `ITAR Pilot Ring – Stage1`. Run `DLPITAR-Scope-Health.ps1` to see the coverage map.

Matches appear in simulation but nothing is blocked.

• That is **correct** — simulation records what *would* have happened without enforcing. To restrict egress,

the policy must be promoted to **enforce** (`DLPITAR-Set-Policy.ps1 -PromoteToEnforce -Commit`) after the gates pass and export/legal approve. If you expected blocking, you are still in test mode.

The `Devices/Endpoint` location isn't available when creating or scoping the policy.

• **Licensing:** Endpoint DLP generally requires **E5 / E5 Compliance / A5** — confirm in the admin center

and with `DLPITAR-Scope-Health.ps1` (verify your licensing/tenant).

• **Onboarding:** the Devices location depends on **onboarded devices** — check **Purview portal → Settings

→ Device onboarding**. With no onboarded devices the location does nothing even when selectable.

Egress behaviour

External send/share isn't being restricted after enforcement.

• Confirm the rule's **scope condition** actually targets egress outside the org (recipient/share scope is

`NotInOrganization` / "outside the organization") and that the **action** is Block / block-with-override — a rule that only *notifies* will not restrict. `DLPITAR-Validation.ps1 -ExpectEnforce` checks for both.

• Some condition/action combinations are **portal-only** in a given tenant — the config helper creates a

safe simulation shell and prints exactly what to finish in the portal. Complete the label condition, external scope, and Block action there, then re-validate.

• SharePoint/OneDrive **external sharing** is also governed by tenant/site sharing settings — a DLP block and

the sharing configuration must both be consistent with the intended restriction.

Endpoint activities (USB / print / cloud upload) aren't caught after enforcement.

• Confirm the device is **onboarded and reporting**, meets the **minimum OS build**, and that the specific

activity is in scope of the rule (e.g. "copy to USB" enabled) and not on an **allowed app / network** exception. Allow for **reporting latency** — endpoint events take time to surface in Activity Explorer.

False positives (the adoption killer)

Engineers are getting policy tips on legitimate internal work.

• Export matches with `DLPITAR-Report.ps1 -CsvPath ...`, classify TP/FP, and identify the driver.

• **Raise confidence/instance count**, add **supporting keywords/proximity**, and prefer the **label

condition **so context is required, not just a pattern. Move over-matching identifier sets to** EDM** where licensed.

• Add a **targeted exception** only where export-compliance has justified it (a specific mailbox/site/group),

narrowly and with a documented reason recorded in `Change Record – ITAR DLP – ChangeControl`.

• Re-simulate after each change and re-measure — don't stack multiple changes blind.

Alerts / evidence

Policy matches occur but no alert appears / the report returns nothing.

• Confirm **alerts are configured** on the rule and check **Purview** → **Data loss prevention** → **Alerts**.

• Confirm **audit logging is enabled** in the tenant — `DLPITAR-Report.ps1` reads the unified audit log and

will return nothing without it. Widen `-Days` for latency, and allow **dwell time** on fresh policies.

• Confirm your account holds a **View-Only DLP / audit** role; a missing role looks like "no data."

Reviewers can see too much (or too little) match evidence.

• Match evidence for controlled technical data is itself sensitive — access is governed by **role**. Confirm reviewers hold the least-privilege **Data Loss Prevention / View-Only DLP** role and nothing broader.

Connectivity / tooling

`Connect-IPPSSession` **or a DLP cmdlet fails.**

• Ensure **ExchangeOnlineManagement** is installed/updated and you're using a **modern-auth / MFA-capable**

admin. For a sovereign cloud, pass the correct `-ConnectionUri` (Commercial / GCC High / DoD).

• Confirm the account holds the required **DLP role** (Compliance Administrator / Compliance Data Administrator / DLP Compliance Management) — a missing role surfaces as "cmdlet not recognized" or access denied.

A script made an unexpected change.

• The delivered scripts are **read-only or** `-WhatIf` **by default**; writes require `-Commit`. If a change landed it was committed intentionally — the safe recovery is always `DLPITAR-Set-Policy.ps1 -Disable -Commit` (or back to `-Mode TestWithNotifications -Commit`), which is instant and non-enforcing.

Fast triage table

Symptom	First check
Technical-data SIT never fires	Test regex+keywords+proximity in the SIT wizard; prefer the label condition
SIT over-matches routine docs	Require keywords, tighten proximity, raise confidence/instance, or move to EDM
Policy matches nothing	Mode (disable/sim), propagation time, workload scope/exclusion, pilot-ring membership
Nothing blocked	Still in **simulation** — expected; promote to enforce after gates pass + approval
External send/share not restricted	Rule scope = NotInOrganization, action = Block, finish portal-only conditions, re-validate
Devices location missing	Licensing (E5/E5 Compliance/A5) + device **onboarding**
Endpoint activity not caught	Device onboarded/reporting, activity in scope, allowed app/network exceptions, latency
Too many false positives	Export/classify with Report, tune one driver, prefer label/EDM, re-simulate
No alert / report empty	Alert config on rule, audit logging on, widen -Days, dwell time, View-Only DLP role

Symptom	First check
Evidence access wrong	Least-privilege DLP role on reviewers
Cmdlet/connect fails	Module updated, modern auth, correct `-ConnectionUri`, correct DLP role

> ***Boundary reminder.*** *These are the *technical* fixes. Whether an item is ITAR-controlled technical data, who is a foreign person, the deemed-export access question, and the enforced action per case remain* ***Empowered Official / export-compliance / legal*** *determinations — captured alongside the evidence, not decided here.*

Best Practices — ITAR DLP Pack in Microsoft Purview

Field-tested guidance for running technical-data DLP well. It follows the same order the solution is built: get **detection** right, pilot in **simulation**, enforce **proportionately**, and keep the **evidence** intact — deferring every export determination to the accountable owners.

1. Detection is the product — invest the pilot time there

- The difference between a DLP program that works and one that gets turned off is **detection accuracy**.

Budget most of the pilot for tuning the technical-data classification, not for building the policy.

- Prefer the `Export Controlled // ITAR` **sensitivity label** as the primary DLP condition. A label

travels with the item, survives copy/rename, and is the most precise and durable signal — far better than trying to regex every possible marking. Use marking/keyword SITs to *find* content to label and as a backstop, not as the only signal.

2. Never make the export determination in the tool

- Whether an item **is** ITAR-controlled technical data, whether a person is a **U.S. person** or a

foreign person, USML categorization, ITAR-vs-EAR jurisdiction, and licensing/authorization are **legal/export determinations** made by your **Empowered Official and export-compliance function** (`global-requirements-purview.md` §5). The DLP pack implements and evidences the control; it does not classify the data or the person.

- Capture those determinations in writing **before** enforcing, and reference them in the change record.

3. Always pilot in simulation/test first

- **DLP** → `TestWithNotifications` **/** `TestWithoutNotifications` is a non-negotiable first state. It proves

the classification matches and the egress rule *would* act **without disrupting engineering work**.

- Keep the pilot scoped to `ITAR Pilot Ring – Stage1` and expand **group-by-group** — never flip to

enforce, tenant-wide, in one move. Re-run the validation gates after each expansion.

4. Make the egress action proportionate

• Reserve the hardest action (hard **block external send/share**) for the highest-confidence signal

(labeled content, or high-confidence marking matches). Prefer **block-with-override / justification** for lower-confidence matches so legitimate, authorized transfers have a documented path.

• A false block on a defense program stops mission work; a missed egress is an export exposure. Tune so the

rule is tight on real technical data and quiet on routine internal collaboration.

5. Cover every egress channel — email is not enough

• Technical data leaves through **email, external sharing, Teams, and endpoints** (USB, print, cloud

upload). A mail-only policy leaves removable media and personal-cloud upload wide open — classic ITAR gaps. Extend to **Endpoint DLP** as soon as E5 and device onboarding allow.

• Make coverage **explicit and licensing-aware** with `DLPITAR-Scope-Health.ps1`; record any un-covered

channel as a known gap rather than assuming it is protected.

6. Know the boundary between egress control and deemed-export access

• DLP as built here controls **egress out of the tenant**. Preventing a **foreign person inside your

tenant **from *accessing* technical data (the classic** deemed export**) is an** access-control **problem — sensitivity-label encryption/permissions, site/library access, and Conditional Access — driven by a** legal foreign-person determination**. Do not assume egress DLP closes the deemed-export gap.

• Flag deemed-export access as a distinct program dependency and route it to your export authority; this

pack is honest about where its control ends.

7. Confirm the right sovereign cloud before you build

• Defense programs frequently require **GCC High** or **DoD**. Capability availability, portal paths, and

Graph/PowerShell endpoints differ across **Commercial / GCC High / DoD**. Which cloud your ITAR data must reside in is an **export/legal determination** — confirm it before relying on any path, and pass the matching `-ConnectionUri` / Graph environment to the scripts.

8. Change everything under control, `-WhatIf` first

• Every configuration change runs `-WhatIf` **first**, is applied only with `-Commit` under a change

window, and is stamped into `Change Record – ITAR DLP – ChangeControl`. Promotion to enforce is a reviewed, reversible event — rollback to test/disabled is a single command.

9. Baseline and watch for drift

- Establish a **policy baseline** (`DLPITAR-Discovery.ps1 -SaveBaseline`) after each approved change set and

run `-CompareBaseline` on a cadence. An ITAR egress policy that silently moved to `Disable` is a change-control incident, not a footnote.

10. Verify against your tenant — the surfaces evolve

- Purview DLP, Endpoint DLP, EDM, and the exact portal paths are **licensing-dependent** and the portals

change. Confirm capability availability and exact paths **against your licensing/tenant** rather than assuming; where a capability is in preview, treat it as such.

11. Keep the evidence trail intact

- Do **not** delete DLP alerts, matched-content records, or audit entries to "clean up" — they are the

defensible, auditor-facing evidence that the technical-data control is live and working. Retention and disposition of those records is a **records/legal determination**, not an admin convenience.

8. Deliverables Summary — ITAR DLP Pack (Microsoft Purview)

What you receive in this solution, and what "done" looks like.

Documentation

Document	What it gives you
Solution Overview	The ITAR technical-data DLP model — the export-marking classification (custom SIT / keyword dictionary), the optional `Export Controlled // ITAR` sensitivity label, the egress control across email, SharePoint, OneDrive, Teams, and endpoint, the evidence artifact, and the simulate→enforce journey; naming convention and the export-determination boundary.
Requirements Guide	Solution-specific prerequisites (DLP/Endpoint/EDM licensing and the correct cloud environment, least-privilege DLP roles, in-scope workloads, the technical-data classification intent, the pilot ring, Empowered Official / export-compliance stakeholders, and alert/evidence routing) each with verify/implement steps, on top of the six category prerequisites.

Document	What it gives you
Implementation Guide	The exact ordered phases: assess + scope/licensing → design the technical-data detection (prefer the label) → build the policy `ITAR Technical-Data Egress – AllWorkloads – Pilot` **in simulation/test** → pilot & tune → validate gates → (approval) promote to **enforce** → expand → run the evidence cadence; each artifact named, each phase gated with a rollback.
Testing & Validation	Pass/fail gates covering discovery, scope/coverage, simulation matching, tuned false-positive rate, validation-before-enforce, enforced-action verification, and rollback — all exercised with **synthetic/fabricated** technical-data test content only.
Troubleshooting Guide	The common failure modes (classification not firing or over-firing, policy mode/scope wrong, egress not restricted, endpoint activities missed, false-positive floods, no alert/empty report, connectivity) and how to resolve them.
Best Practices	Simulate-first discipline, marking-and-label-based detection, false-positive tuning, the egress-vs-deemed-export boundary, sovereign-cloud considerations, endpoint specifics, evidence cadence, and change governance.
Executive Summary	One-page business framing for approvers and the export-compliance function.

PowerShell tools (5) — Security & Compliance PowerShell / Graph

All tools are **read-only or `-WhatIf` by default**; writes require an explicit `-Commit`, and the config tool never enforces without `-PromoteToEnforce -Commit`. No credentials are stored in code. They connect via `Connect-IPPSSession` (use the `-ConnectionUri` for your cloud — Commercial / GCC High / DoD) and/or Graph.

#	Script	Role	Default safety
1	**DLPITAR-Discovery.ps1**	DLP posture + technical-data classification assessment: existing policies/rules and their mode, available sensitive-information-types, whether a technical-data classification already exists; writes/compares the policy baseline (`-SaveBaseline` / `-CompareBaseline`) for drift detection.	Read-only
2	**DLPITAR-Set-Policy.ps1**	Configuration/remediation helper: creates the policy `ITAR Technical-Data Egress – AllWorkloads – Pilot` and rule `Technical-Data Egress Rule – Markings+Label – v1` **in simulation/test**; `-PromoteToEnforce` enables enforcement, `-Disable` rolls back.	`-WhatIf` (writes need `-Commit`; enforce only via `-PromoteToEnforce -Commit`)
3	**DLPITAR-Scope-Health.ps1**	Scope/health helper: produces `Workload Scope – ITAR DLP – Map` — which workloads are in scope, endpoint onboarding status, and which DLP surfaces the licensing unlocks.	Read-only
4	**DLPITAR-Validation.ps1**	Validation checker: confirms the policy is in the expected mode, scoped to the intended workloads, and that the rule references the technical-data classification with an external-egress scope/action — reports pass/fail per gate.	Read-only

#	Script	Role	Default safety
5	**DLPITAR-Report.ps1**	Evidence report: produces `ITAR DLP Evidence – Egress – Report` — matches by workload/recipient scope and admin action, from the unified audit log, for TP/FP tuning and export-compliance evidence.	Read-only

Definition of done

• Technical-data detection defined for the markings/identifiers in scope (custom SIT / keyword dictionary,

and where used the `Export Controlled // ITAR` label; EDM where licensed and needed).

• The ITAR DLP policy built across the in-scope workloads and **proven in simulation/test** on

`ITAR Pilot Ring – Stage1`.

• False-positive rate measured with `DLPITAR-Report.ps1` and tuned to a level export-compliance accepts;

routine engineering work not flagged.

• Validation gates green (`DLPITAR-Validation.ps1`) and simulation results signed off before enforcement.

• Enforcement live (external send/share restricted; endpoint channels added as licensing allows), with a

verified single-command rollback to test/disabled.

• Evidence artifact (`ITAR DLP Evidence – Egress – Report`) produced on cadence with least-privilege access;

drift monitored via `-CompareBaseline`; change log captured in `Change Record – ITAR DLP – ChangeControl`.

> ***Boundary:*** *the solution delivers the technical DLP control and the evidence. Whether an item* ***is*** *ITAR-controlled technical data,* ***who is a foreign person****, USML categorization, jurisdiction (ITAR vs EAR), authorization/licensing, and* ***deemed-export*** *access are* ***Empowered Official / export-compliance / legal*** *determinations — captured alongside the evidence, not decided by this pack.*

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

DLPITAR-Discovery.ps1

Purpose: Connects to Security & Compliance PowerShell and inventories the tenant's current Data Loss Prevention estate for the ITAR technical-data DLP pack: existing DLP policies and their modes, DLP rules, the sensitive-information-types available, any custom technical-data / export-controlled SIT already present, and (where readable) sensitivity labels that could key the DLP rule. Read-only: it changes nothing. With -SaveBaseline it writes a JSON baseline of policy names+modes; with -CompareBaseline it diffs the live estate against that baseline and reports drift (e.g. a policy silently moved to Disable). HOW TO RUN Inventory (read-only, default): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Discovery.ps1 Save a drift baseline once the estate is known-good: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Discovery.ps1 -SaveBaseline Detect drift against the baseline: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Discovery.ps1 -CompareBaseline

How to run: Inventory (read-only, default): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Discovery.ps1 Save a drift baseline once the estate is known-good: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Discovery.ps1 -SaveBaseline Detect drift against the baseline: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Discovery.ps1 -CompareBaseline

DLPITAR-Report.ps1

Purpose: Produces the "ITAR DLP Evidence - Egress - Report" artifact: the DLP rule matches for the ITAR technical-data policy over a time window, broken down by workload and recipient/scope so you can (a) tune true-positive vs false-positive during the pilot and (b) evidence what the policy detects and the admin action once enforcing. Works for policies in SIMULATION and in enforcement — simulation matches are logged the same way. Read-only: queries Search-UnifiedAuditLog only and changes nothing. (Activity Explorer in the portal and Microsoft Graph security alerts are equivalent sources — verify availability against your licensing/tenant.) HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPITAR-Report.ps1 -Days 14 -CsvPath .\ITAR-DLP-Evidence.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled in the tenant. EXAMPLE .\DLPITAR-Report.ps1 -Days 14 -CsvPath .\ITAR-DLP-Evidence.csv Summarises matches by workload and policy and exports a per-event CSV with a blank Disposition column. NOTES White-label. Read-only reporting from the unified audit log. No changes made. No credentials in code. Expected results: during pilot, classify each row TP/FP and compute FP rate = FP / (TP+FP); when enforcing, the report is the evidence you show a reviewer. Verify capability/paths against your tenant. > [CmdletBinding()] param([int] $Days = 14, [string] $PolicyName = 'ITAR Technical-Data Egress - AllWorkloads - Pilot', [string] $CsvPath, [string] $ConnectionUri = 'https://ps.compliance.protection.outlook.com/powershell-liveid/')

How to run: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Report.ps1 -Days 14 -CsvPath .\ITAR-DLP-Evidence.csv Requires Security & Compliance PowerShell (Connect-IPPSSession) and audit logging enabled in the tenant. EXAMPLE .\DLPITAR-Report.ps1 -Days 14 -CsvPath .\ITAR-DLP-Evidence.csv Summarises matches by workload and policy and exports a per-event CSV with a blank Disposition column. NOTES White-label. Read-only reporting from the unified audit log. No changes made. No credentials in code. Expected results: during pilot, classify each row TP/FP and compute FP rate = FP / (TP+FP); when enforcing, the report is the evidence you show a reviewer. Verify capability/paths against your tenant. > [CmdletBinding()] param([int] $Days = 14, [string] $PolicyName =

'ITAR Technical-Data Egress - AllWorkloads - Pilot', [string] $CsvPath, [string] $ConnectionUri = 'https://ps.compliance.protection.outlook.com/powershell-liveid/')

DLPITAR-Scope-Health.ps1

Purpose: Produces the "Workload Scope - ITAR DLP - Map": for each M365 egress channel (Exchange, SharePoint, OneDrive, Teams, and Endpoint devices) it reports whether an existing DLP policy already covers it, and flags the licensing-dependent surfaces (Endpoint DLP, Exact Data Match, trainable classifiers) that generally require Microsoft 365 E5 / E5 Compliance. It also checks whether an EDM schema exists (a hint that EDM is licensed/onboarded). Read-only: it changes nothing. Its job is to make coverage EXPLICIT and licensing-aware so an un-onboarded channel is recorded as a gap, never assumed protected. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\DLPITAR-Scope-Health.ps1

How to run: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Scope-Health.ps1

DLPITAR-Set-Policy.ps1

Purpose: Configuration/remediation tool for the ITAR technical-data DLP policy. It DEFAULTS TO -WhatIf (preview only) and writes NOTHING until you re-run with -Commit. Its jobs: Create the policy "ITAR Technical-Data Egress - AllWorkloads - Pilot" and its detection rule "Technical-Data Egress Rule - Markings+Label - v1" in a SIMULATION/TEST mode (TestWithNotifications / TestWithoutNotifications) — nothing blocks. The rule keys on the technical-data classification (a custom SIT and/or the "Export Controlled // ITAR" sensitivity label) with the ITAR-relevant egress condition (recipient/scope is OUTSIDE the organization) and the staged action (Block / notify). -PromoteToEnforce sets the policy Mode = Enable (the configured egress action applies). -Disable rolls the policy back to Disable (instant, non-enforcing). The exact rule conditions (label condition, external-recipient scope, action) may be finished in the PORTAL where a parameter is not exposed in your tenant — the script creates a safe simulation-mode shell and prints precisely what to complete. It never enforces without -PromoteToEnforce -Commit, and never hard-codes credentials. HOW TO RUN Preview the intended policy (default, no change): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -SitName "Technical Data SIT - Export Markings - Custom" Create it in SIMULATION mode (still no enforcement): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -SitName "Technical Data SIT - Export Markings - Custom" -Mode TestWithNotifications -Commit Promote to ENFORCE (in a change window, after gates pass): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -PromoteToEnforce -Commit Roll back: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -Disable -Commit

How to run: Preview the intended policy (default, no change): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -SitName "Technical Data SIT - Export Markings - Custom" Create it in SIMULATION mode (still no enforcement): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -SitName "Technical Data SIT - Export Markings - Custom" -Mode TestWithNotifications -Commit Promote to ENFORCE (in a change window, after gates pass): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -PromoteToEnforce -Commit Roll back: powershell -ExecutionPolicy Bypass -File .\DLPITAR-Set-Policy.ps1 -Disable -Commit

DLPITAR-Validation.ps1

Purpose: Checks the ITAR technical-data egress DLP policy against the Step-5 pass/fail gates and prints one PASS/FAIL line per gate: the policy "ITAR Technical-Data Egress - AllWorkloads - Pilot" exists and is in the EXPECTED mode (SIMULATION during pilot; Enable only when -ExpectEnforce is passed

post-promotion), it is scoped to the intended workloads (Exchange / SharePoint / OneDrive / Teams; Endpoint where designed), the detection rule "Technical-Data Egress Rule - Markings+Label - v1" is present and references the technical-data classification (the custom SIT and/or the "Export Controlled // ITAR" label) with an external-recipient / external-share scope. Read-only — it queries Get-DlpCompliancePolicy / Get-DlpComplianceRule and changes nothing. Run it immediately before promoting to enforce, and again afterwards with -ExpectEnforce to confirm the enforced state. HOW TO RUN Validate the pilot (expects SIMULATION): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Validation.ps1 Validate after promotion (expects Enable): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Validation.ps1 -ExpectEnforce Prereqs: ExchangeOnlineManagement (Connect-IPPSSession); a Compliance/DLP read role. No credentials in code. EXPECTED RESULTS Every gate PASS during pilot (policy in simulation, correctly scoped, rule references the classification) = gates green, safe to seek enforce approval. Any FAIL = fix in test mode and re-validate before enforcing. Exit code 1 on any FAIL. .NOTES White-label. Read-only against Security & Compliance PowerShell. No credentials in code. Verify capability/paths against your licensing/tenant. ITAR/export/legal determinations deferred to the owners. > [CmdletBinding()] param([string] $PolicyName = 'ITAR Technical-Data Egress - AllWorkloads - Pilot', [string] $RuleName = 'Technical-Data Egress Rule - Markings+Label - v1', [string] $SitName = 'Technical Data SIT - Export Markings - Custom', [string] $LabelName = 'Export Controlled // ITAR', [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]] $ExpectedLocations = @('Exchange','SharePoint','OneDrive','Teams'), [switch] $ExpectEnforce, [string] $ConnectionUri = 'https://ps.compliance.protection.outlook.com/powershell-liveid/')

How to run: Validate the pilot (expects SIMULATION): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Validation.ps1 Validate after promotion (expects Enable): powershell -ExecutionPolicy Bypass -File .\DLPITAR-Validation.ps1 -ExpectEnforce Prereqs: ExchangeOnlineManagement (Connect-IPPSSession); a Compliance/DLP read role. No credentials in code. EXPECTED RESULTS Every gate PASS during pilot (policy in simulation, correctly scoped, rule references the classification) = gates green, safe to seek enforce approval. Any FAIL = fix in test mode and re-validate before enforcing. Exit code 1 on any FAIL. .NOTES White-label. Read-only against Security & Compliance PowerShell. No credentials in code. Verify capability/paths against your licensing/tenant. ITAR/export/legal determinations deferred to the owners. > [CmdletBinding()] param([string] $PolicyName = 'ITAR Technical-Data Egress - AllWorkloads - Pilot', [string] $RuleName = 'Technical-Data Egress Rule - Markings+Label - v1', [string] $SitName = 'Technical Data SIT - Export Markings - Custom', [string] $LabelName = 'Export Controlled // ITAR', [ValidateSet('Exchange','SharePoint','OneDrive','Teams','Endpoint')] [string[]] $ExpectedLocations = @('Exchange','SharePoint','OneDrive','Teams'), [switch] $ExpectEnforce, [string] $ConnectionUri = 'https://ps.compliance.protection.outlook.com/powershell-liveid/')